Quiz — Threat modeling / SSDLC

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

1. Why / how: An attacker presents a stolen session cookie and releases held mail. Which STRIDE categories light up first, and **why** is Spoofing distinct from Elevation of privilege here?

2. How: In one sentence each, what do Shostack's four questions force you to write down that a vague "we'll be careful" skips?

3. Why: Why map a mitigation to **NIST SSDF** / **OWASP ASVS** evidence (and treat **SAMM** as an optional maturity *map*) rather than claiming a certification wall for this assignment?

4. Scenario: Held message bodies are readable by every authenticated operator, and audit logs retain full bodies for 2 years. Which STRIDE (and optional LINDDUN) concerns apply, and what mitigation would you prioritize first?

5. Scenario: Operators can release holds without MFA. Walk the abuse story: who is spoofed, what is elevated, and what fails without audit (**Repudiation**)?

6. Spot the bug / why: A STRIDE table lists only "malware" as the threat for every row. What reasoning is missing, and why does that fail a design review?